
Informe de Pentesting

Actividad A08 — Hacking Ético

Cliente: INSECUR S.A. — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información

Licenciatura en Sistemas de Información — Facultad de Informática y Diseño

Docente: Ing.

Rodrigo Atilio Elgueta

Ciclo Académico Vigente

Alumno: Martinengo, Nicolas — Username TryHackMe: martinengodiegonicolas

Índice

1. Contexto de la Contratación	2
2. Modelo de Trabajo: Núcleo + Sala de Elección	2
2.1. Nivel 1 — Núcleo obligatorio (todos los estudiantes)	2
2.2. Nivel 2 — Sala de elección (una por estudiante)	2
3. Configuración del Entorno	3
3.1. Requisitos previos	3
3.2. Conexión a la VPN de TryHackMe	3
4. Mecanismos de Control de Autenticidad	3
5. PARTE I: GUÍA DE TRABAJO EN TRYHACKME	4
5.1. Flujo profesional del pentesting	4
6. PARTE II: INFORME	4
6.1. Datos generales	4
6.2. Pre-pentesting	5
6.3. Durante: Hallazgos por fase	5
6.4. Resumen ejecutivo de hallazgos	11
6.5. Post-pentesting: Recomendaciones	11
7. PARTE III: PROTOCOLO DE CONTINGENCIA	12
8. Anexos	13
9. Fuentes y bibliografía	13

1. Contexto de la Contratación

Carta de Autorización — INSECUR S.A.

Ciente: INSECUR S.A.

Contratista: Estudiante de Seguridad Aplicada a Sistemas de Información (FID-UCH).

Objeto del contrato: La compañía INSECUR S.A., preocupada por los niveles de seguridad de sus sistemas, contrata sus servicios profesionales de **Hacking Ético** para elaborar un plan de seguridad y contingencia.

Alcance autorizado: Únicamente los entornos de laboratorio de la plataforma **TryHackMe** asignados en esta guía. Cualquier acción fuera de este alcance queda estrictamente prohibida y constituye un delito conforme la legislación vigente.

Entregable: Informe profesional de pentesting, incluyendo documentación previa, durante y posterior a la intervención, más un protocolo de contingencia para garantizar la continuidad de negocio.

Modalidad: Individual.

Repositorio de entrega: https://github.com/UCHSeguridad2026/TP_THM.git (branch martinengo-nicolas).

Ética y Legalidad

Esta actividad se desarrolla en **entornos controlados (sandbox)**. Queda absolutamente prohibido aplicar las técnicas aprendidas contra sistemas reales sin autorización escrita. El incumplimiento será considerado falta ética grave y podrá derivar en sanciones académicas y legales.

2. Modelo de Trabajo: Núcleo + Sala de Elección

La actividad se estructura en dos niveles que garantizan una base común y, al mismo tiempo, diversidad en los casos trabajados.

2.1. Nivel 1 — Núcleo obligatorio (todos los estudiantes)

Núcleo Obligatorio

1. Pentesting Fundamentals

<https://tryhackme.com/room/pentestingfundamentals>

Metodología y fases del pentesting profesional.

2. Basic Pentesting

<https://tryhackme.com/room/basicpentestingjt>

Aplicación práctica completa: enumeración, explotación y escalada de privilegios.

2.2. Nivel 2 — Sala de elección (una por estudiante)

Sala elegida: Kenobi (<https://tryhackme.com/room/kenobi>) — Linux, Samba + ProFTPD + escalada de privilegios por manipulación de variable PATH sobre un binario SUID. Se eligió por complementar, sin solaparse, el enfoque de Basic Pentesting (que se centró en fuerza bruta de credenciales SSH y pivoteo entre usuarios): Kenobi aporta explotación de un servicio de red sin au-

tenticación (ProFTPD `mod_copy`) y una técnica de escalada de privilegios distinta (PATH hijacking sobre SUID).

3. Configuración del Entorno

3.1. Requisitos previos

1. Cuenta gratuita en <https://tryhackme.com> (username: martinengodiegonicolas).
2. Kali Linux (VM) con las herramientas básicas: `nmap`, `gobuster`, `hydra`, `smbclient`, `john`, `searchsploit`, `netcat`.
3. Cliente OpenVPN instalado (para la VPN de THM).
4. Cuenta de GitHub con acceso al repositorio de la cátedra.

3.2. Conexión a la VPN de TryHackMe

```
1 sudo openvpn --config ~/Downloads/us-east-1-martinengodiegonicolas-regular.ovpn
```

Nota de campo

Durante la ejecución del TP se observó una falla de conexión VPN por bloqueo del puerto UDP 1194 en la red de origen; se resolvió reconectando a través de datos móviles. Asimismo, la VM atacante sufrió un cuelgue (posiblemente por consumo excesivo de RAM con múltiples terminales abiertas) que obligó a reiniciarla y repetir parte de la cadena de explotación de Kenobi. En ambos casos la máquina objetivo de TryHackMe no se vio afectada, lo que permitió verificar la reproducibilidad de los hallazgos (ver bitácora).

4. Mecanismos de Control de Autenticidad

Username único de TryHackMe

Username público de THM: **martinengodiegonicolas**.

Bitácora de comandos

Bitácoras sanitizadas (sin contraseñas/claves en texto plano) en `bitacora/clase_01_basicpentesting_20261007.txt` y `bitacora/clase_02_kenobi_20261007.txt`.

Evidencias con marca de identidad

Capturas en `evidencias/`, organizadas por fase y por sala (prefijo `BP_` para Basic Pentesting, `KN_` para Kenobi, `NUCLEO_` para Pentesting Fundamentals).

Hash de las flags

Ver Anexo C.

Commits firmadosCommits realizados en la rama `martinengo-nicolas` del repositorio de la cátedra.

5. PARTE I: GUÍA DE TRABAJO EN TRYHACKME

5.1. Flujo profesional del pentesting

Fase	Acciones típicas	Herramientas
Pre-engagement	Definir alcance, reglas de enfrentamiento, autorización	Plantilla, firma de ROE
Reconocimiento	OSINT, enumeración pasiva, descubrimiento de activos	theHarvester, whois, DNSdumper
Escaneo	Descubrimiento de puertos, servicios y versiones	Nmap, Nikto, Gobuster
Enumeración	Análisis detallado de cada servicio encontrado	Netcat, enum4linux, SNMPwalk
Explotación	Aprovechar vulnerabilidades para obtener acceso	Metasploit, Searchsploit, Burp Suite
Post-explotación	Escalada de privilegios, movimiento lateral, persistencia	LinPEAS, WinPEAS, mimikatz
Reporte	Documentación, remediación, protocolo de contingencia	Plantilla de informe

6. PARTE II: INFORME

6.1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno/a)	Martinengo, Nicolas
DNI	45714926
Username TryHackMe	martinengodiegonicolas
Email institucional	martinengodiegonicolas@uch.edu.ar
Sala de elección (Nivel 2)	Kenobi (https://tryhackme.com/room/kenobi)
Branch en GitHub	<code>martinengo-nicolas</code>
Fecha de inicio	07/10/2026
Fecha de cierre	07/10/2026

6.2. Pre-pentesting

Alcance del trabajo

Dentro de alcance: las máquinas virtuales de laboratorio de las salas *Pentesting Fundamentals*, *Basic Pentesting* y *Kenobi* de TryHackMe, accedidas mediante la VPN de la plataforma (direcciones IP asignadas dinámicamente por TryHackMe dentro de su rango de laboratorio).

Fuera de alcance: cualquier sistema de producción real; la infraestructura de la cátedra, de la universidad o de terceros; cualquier otra máquina o usuario de TryHackMe no asignado explícitamente a este ejercicio; y cualquier técnica de denegación de servicio.

Reglas de Enfrentamiento (ROE)

Las pruebas se realizaron exclusivamente contra las IPs asignadas por TryHackMe (10.66.167.203 para Basic Pentesting y 10.66.186.232 para Kenobi) dentro de la VPN de laboratorio provista por la plataforma. No se utilizaron técnicas de denegación de servicio ni ataques destructivos sobre los sistemas objetivo. Ante incidentes propios del entorno de trabajo (caída de la VPN por bloqueo de UDP 1194, y un cuelgue de la máquina atacante por consumo de recursos), se documentó lo ocurrido en la bitácora y se reanudó el trabajo sin alterar el estado de las máquinas objetivo más allá de lo necesario para completar los objetivos de cada sala.

Autorización

Declaro contar con autorización expresa de la cátedra de Seguridad Aplicada a Sistemas de Información (FID-UCH) para realizar las actividades de hacking ético descritas en este informe, exclusivamente sobre los entornos de laboratorio de TryHackMe indicados, en el marco de la Actividad A08.

Metodología utilizada

Se siguió una adaptación simplificada de **PTES** (Penetration Testing Execution Standard), recorriendo las fases de Reconocimiento, Escaneo, Enumeración, Explotación y Post-explotación. Se eligió este marco por ajustarse mejor a pruebas de intrusión sobre servicios de red (SSH, FTP, SMB, NFS, Tomcat) con alcance acotado y objetivos técnicos concretos (obtención de acceso y escalada de privilegios), a diferencia de marcos orientados específicamente a aplicaciones web (p. ej. OWASP WSTG), que no se ajustan por completo al tipo de activos evaluados en estas dos salas.

El trabajo se desarrolló de forma incremental, en más de una sesión y dispositivo (continuando en algunos tramos desde una computadora distinta a la utilizada inicialmente), registrando el avance mediante bitácoras de comandos (Anexo A) y commits incrementales sobre la rama personal del repositorio de la cátedra, lo que permite reconstruir la evolución cronológica de cada hallazgo.

6.3. Durante: Hallazgos por fase

Campo	Valor
ID del hallazgo	H-01

Fase	■ Reconocimiento ☐ Escaneo ☐ Explotación ☐ Post-explotación
Descripción	Superficie de ataque amplia en Basic Pentesting: nmap reveló SSH (22), HTTP/Apache (80), Samba (139/445), Apache Jserv/AJP (8009) y Tomcat 9.0.7 (8080) expuestos simultáneamente, con /development/ descubierto por fuerza bruta de directorios (gobuster).
Componente afectado	Host 10.66.167.203 (Basic Pentesting)
Categoría (OWASP / CWE)	CWE-1059 (Insufficient Technical Documentation) / exposición de superficie de ataque
CVE (si aplica)	—
CVSS estimado	■ Bajo ☐ Medio ☐ Alto ☐ Crítico
Evidencia (captura / comando)	evidencias/reconocimiento/BP_reconocimiento_H01_nmap.png
Herramienta utilizada	Nmap, Gobuster
Impacto en la Tríada CIA	■ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Reducir servicios expuestos al mínimo necesario; segmentar servicios administrativos (Tomcat) de servicios públicos.
Riesgo residual tras aplicar	■ Bajo ☐ Medio ☐ Alto
Campo	Valor
ID del hallazgo	H-02
Fase	☐ Reconocimiento ☐ Escaneo ☒ Explotación ☐ Post-explotación
Descripción	Credencial SSH débil del usuario jan (armando) , presente en diccionarios comunes, obtenida por fuerza bruta con Hydra en pocos minutos y sin bloqueo de cuenta tras múltiples intentos fallidos.
Componente afectado	Servicio SSH (puerto 22), host 10.66.167.203
Categoría (OWASP / CWE)	CWE-521 (Weak Password Requirements)

CVE (si aplica)	—
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico
Evidencia (captura / comando)	evidencias/escaneo/BP_escaneo_H02_gobuster-hydra.png
Herramienta utilizada	Hydra
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Política de contraseñas robustas, autenticación por clave pública obligatoria, bloqueo de cuenta tras N intentos fallidos (fail2ban), limitar intentos por IP.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto
Campo	Valor
ID del hallazgo	H-03
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☒ Post-explotación
Descripción	Movimiento lateral desde jan hacia kay : la clave privada SSH de kay pudo copiarse desde la cuenta de jan (tras un intento inicial bloqueado por permisos, un segundo intento vía scp tuvo éxito), y su passphrase (beeswax) fue crackeada offline con John the Ripper y la wordlist rockyou.txt en segundos.
Componente afectado	Sistema de archivos / claves SSH, host 10.66.167.203
Categoría (OWASP / CWE)	CWE-522 (Insufficiently Protected Credentials)
CVE (si aplica)	—
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico
Evidencia (captura / comando)	evidencias/post/BP_post_H05_scp-clave-john-crack.png, BP_post_H06_passphrase-crackeada-ssh-kay.png
Herramienta utilizada	scp, ssh2john, John the Ripper
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☐ Disponibilidad

Salvaguarda propuesta	pro-	Permisos restrictivos sobre directorios <code>.ssh</code> de cada usuario; passphrases robustas y únicas por clave; revisión periódica de permisos de archivos sensibles.
-----------------------	------	---

Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto
------------------------------	---

Campo	Valor
-------	-------

ID del hallazgo	H-04
-----------------	------

Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☒ Post-explotación
------	--

Descripción	Credencial adicional almacenada en texto plano en el archivo <code>pass.bak</code> dentro del <i>home</i> del usuario <code>kay</code> , recuperable con un simple <code>cat</code> tras obtener acceso a esa cuenta.
-------------	---

Componente afectado	<code>/home/kay/pass.bak</code> , host 10.66.167.203
---------------------	--

Categoría (OWASP / CWE)	CWE-256 (Plaintext Storage of a Password)
-------------------------	---

CVE (si aplica)	—
-----------------	---

CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico
---------------	--

Evidencia (captura / comando)	<code>evidencias/post/BP_post_H07_pass-bak.png</code>
-------------------------------	---

Herramienta utilizada	— (acceso directo al sistema de archivos)
-----------------------	---

Impacto en la Tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
--------------------------	--

Salvaguarda propuesta	pro-	Prohibir el almacenamiento de credenciales en texto plano; usar gestores de secretos (vault) o variables de entorno cifradas; auditorías periódicas de archivos sensibles en <i>homes</i> de usuario.
-----------------------	------	---

Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto
------------------------------	---

Campo	Valor
-------	-------

ID del hallazgo	H-05
-----------------	------

Fase	☒ Reconocimiento ☒ Escaneo ☐ Explotación ☐ Post-explotación
------	---

Descripción	En Kenobi, el share SMB anonymous permite acceso sin autenticación y contiene log.txt , un archivo de configuración con información sensible (generación de la clave SSH de kenobi sin passphrase, configuración interna de ProFTPD). Adicionalmente, NFS exporta el directorio /var completo sin restricción de hosts.
Componente afectado	Samba (139/445) y NFS (111/2049), host 10.66.186.232
Categoría (OWASP / CWE)	CWE-200 (Exposure of Sensitive Information), CWE-732 (Incorrect Permission Assignment)
CVE (si aplica)	—
CVSS estimado	☐ Bajo ☒ Medio ☐ Alto ☐ Crítico
Evidencia (captura / comando)	evidencias/escaneo/KN_escaneo_H02_smbclient_logtxt_inicio.png
Herramienta utilizada	smbclient, showmount, nmap NSE (smb-enum-shares, nfs-showmount)
Impacto en la Tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Restringir acceso anónimo a shares SMB; eliminar archivos de configuración/logs sensibles de ubicaciones compartidas; restringir exportaciones NFS por IP/host y deshabilitar no_root_squash si estuviera activo.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto
Campo	Valor
ID del hallazgo	H-06
Fase	☐ Reconocimiento ☐ Escaneo ☒ Explotación ☐ Post-explotación
Descripción	ProFTPD 1.3.5 vulnerable a CVE-2015-3306 (módulo mod_copy): los comandos FTP SITE CPFR/SITE CPT0 permiten copiar archivos arbitrarios del sistema de archivos sin autenticación . Se explotó para copiar la clave privada SSH de kenobi (/home/kenobi/.ssh/id_rsa) hacia /var/tmp/ , recuperable luego vía el mismo NFS expuesto, obteniendo acceso inicial por SSH sin credenciales propias.
Componente afectado	ProFTPD 1.3.5 (puerto 21), host 10.66.186.232

Categoría (OWASP / CWE)	CWE-862 (Missing Authorization)
CVE (si aplica)	CVE-2015-3306
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico
Evidencia (captura / comando)	evidencias/explotacion/KN_explotacion_H03_ftp_mod_copy_ssh_inicio.png
Herramienta utilizada	netcat (FTP manual), NFS, ssh
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Actualizar ProFTPD a una versión parcheada (posterior a 1.3.5) o deshabilitar <code>mod_copy</code> ; restringir acceso FTP anónimo/no autenticado; segmentar NFS del segmento donde corre el FTP.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto
Campo	Valor
ID del hallazgo	H-07
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☒ Post-explotación
Descripción	El binario <code>/usr/bin/menu</code> tiene bit SUID (propietario <code>root</code>) e invoca internamente <code>curl</code> , <code>uname</code> e <code>ifconfig</code> mediante <code>system()</code> sin ruta absoluta . Anteponiendo <code>/tmp</code> al PATH y colocando allí un ejecutable <code>curl</code> falso (<code>/bin/sh</code>), la opción “status check” del menú ejecuta la shell falsa con privilegios de <code>root</code> , logrando escalada de privilegios completa.
Componente afectado	<code>/usr/bin/menu</code> (SUID root), host 10.66.186.232
Categoría (OWASP / CWE)	CWE-426 (Untrusted Search Path)
CVE (si aplica)	—
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico
Evidencia (captura / comando)	evidencias/post/KN_post_H04_privesc_path_whoami_root.png, KN_post_H05_root_flag.png

Herramienta utilizada	find (-perm -u=s), strings, manipulación de variable PATH
Impacto en la Tríada CIA	■ Confidencialidad ■ Integridad ■ Disponibilidad
Salvaguarda propuesta	Eliminar el bit SUID del binario si no es estrictamente necesario; si lo es, invocar comandos externos siempre con ruta absoluta (/usr/bin/curl) y limpiar/fijar el PATH dentro del propio programa; auditar periódicamente binarios SUID/S-GID del sistema.
Riesgo residual tras aplicar	■ Bajo □ Medio □ Alto

6.4. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	2	H-06, H-07
Alto	3	H-02, H-03, H-04
Medio	1	H-05
Bajo	1	H-01
Total	7	H-01 a H-07

6.5. Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones)

1. **(Crítico)** Actualizar o parchear ProFTPD más allá de la versión 1.3.5, o deshabilitar el módulo mod_copy si no se utiliza (H-06).
2. **(Crítico)** Quitar el bit SUID de /usr/bin/menu o reescribirlo para invocar binarios con ruta absoluta y un PATH controlado internamente (H-07).
3. **(Alto)** Forzar políticas de contraseñas robustas y habilitar bloqueo de cuenta / fail2ban en todos los servicios de autenticación expuestos (H-02).
4. **(Alto)** Restringir permisos de directorios .ssh y claves privadas al propietario exclusivo; exigir passphrases robustas (H-03).
5. **(Alto)** Eliminar credenciales almacenadas en texto plano; migrar a un gestor de secretos (H-04).
6. **(Medio)** Deshabilitar acceso anónimo a shares SMB y restringir exportaciones NFS por host/IP (H-05).
7. **(Bajo)** Reducir la superficie de servicios expuestos al mínimo necesario por host (H-01).

Recomendaciones administrativas (políticas y procesos)

- Política formal de gestión de contraseñas y claves, con rotación y prohibición de credenciales en archivos de texto plano.
- Proceso de gestión de parches con SLA definido para vulnerabilidades críticas/altas (p. ej. 7 días para críticas).
- Auditorías periódicas de binarios SUID/SGID y de permisos de archivos sensibles.
- Capacitación periódica del personal técnico en buenas prácticas de hardening de servicios de red (SSH, FTP, SMB, NFS).
- Revisión de configuración por defecto de todo servicio antes de pasar a producción (Samba, ProFTPD, etc. no deberían conservar configuraciones de ejemplo/documentación).

7. PARTE III: PROTOCOLO DE CONTINGENCIA**Escenario de falla**

La explotación de **H-06** (ProFTPD `mod_copy`) implica copiar archivos arbitrarios en el servidor; un uso malicioso real podría sobrescribir archivos de configuración críticos (por ejemplo, claves de servicio o archivos del propio servidor web/FTP), provocando una caída del servicio FTP o de servicios dependientes. De forma similar, la explotación de **H-07** otorga una shell de root, desde la cual un atacante real podría alterar o destruir datos del sistema.

Impacto sobre la continuidad del negocio

De ocurrir en un entorno productivo de INSECUR S.A., se verían afectados los servicios de transferencia de archivos (FTP), de archivos compartidos (Samba/NFS) y, en el peor caso, cualquier servicio que dependa del mismo host comprometido (dado que un atacante con acceso root tiene control total). El tiempo de indisponibilidad estimado dependería de la existencia de backups y de un plan de reconstrucción del servidor, pudiendo oscilar entre minutos (con automatización y backups recientes) y varias horas (reconstrucción manual).

Plan de respuesta

1. **Activación:** detección mediante monitoreo de integridad de archivos (FIM), alertas de IDS/IPS ante tráfico FTP anómalo (comandos `SITE CPFR/CPT0`), o reportes de usuarios sobre indisponibilidad del servicio.
2. **Contención:** aislar el host afectado de la red (o al menos del segmento expuesto a internet), deshabilitar temporalmente el servicio FTP/Samba/NFS comprometido, y revocar las claves SSH potencialmente filtradas.
3. **Recuperación:** restaurar el servicio desde el último backup íntegro verificado, aplicar el parche de ProFTPD y corregir los binarios SUID vulnerables antes de reincorporar el host a producción.
4. **Comunicación:** notificar a dirección de sistemas y al responsable de seguridad de INSECUR S.A. de inmediato; si hubo exposición de datos de clientes, evaluar notificación a clientes y autoridades conforme la normativa de protección de datos aplicable.
5. **Post-mortem:** documentar la cadena de explotación real, actualizar este informe con los

hallazgos del incidente, y verificar que las salvaguardas propuestas en la Sección 8.3 fueron efectivamente aplicadas.

RTO y RPO estimados

RTO (Recovery Time Objective): 4 horas (restauración de servicio desde backup y aplicación de parches).

RPO (Recovery Point Objective): 24 horas (frecuencia mínima recomendada de backups para estos servicios).

8. Anexos

Anexo A — Bitácora de comandos

bitacora/clase_01_basicpentesting_20261007.txt (sala Basic Pentesting) y bitacora/clase_02_kenobi_20261007.txt (sala Kenobi), ambas en la rama martinengo-nicolas del repositorio de entrega.

Anexo B — Capturas de pantalla

Carpeta evidencias/ con subcarpetas reconocimiento/, escaneo/, explotacion/ y post/. Prefijos de archivo: NUCLEO_ (Pentesting Fundamentals), BP_ (Basic Pentesting), KN_ (Kenobi).

Anexo C — Hashes de las flags/credenciales obtenidas

```

1 # Formato: identificador sha256_hash
2 BP-cred      3
   ffd53ec80858f9ddcd75d69102724ab1bc1020855fff924227f618c4bfccf57
3 KN-user
   bb0f024944a824c077709798ee896f589cccd4198091ab024210bd84aa47e8d6
4 KN-root      9
   c28680c60bda20ba001d979aa378c880670313074446a5ae0cc7b0d234daf18

```

BP-cred: credencial final hallada en *pass.bak* (Basic Pentesting). *KN-user* y *KN-root*: flags de usuario y root de la sala Kenobi.

Anexo D — Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Firma del estudiante

Fecha

9. Fuentes y bibliografía

- TryHackMe. *Pentesting Fundamentals*: [sala oficial](#)
- TryHackMe. *Basic Pentesting*: [sala oficial](#)
- TryHackMe. *Kenobi*: [sala oficial](#)
- MITRE. *CVE-2015-3306 — ProFTPD mod_copy*: [NVD](#)

- PTES. *Penetration Testing Execution Standard*: pentest-standard.org
- OWASP Foundation. *Web Security Testing Guide (WSTG)*: [sitio oficial](#)
- NIST (2008). *Technical Guide to Information Security Testing and Assessment (SP 800-115)*.
- Chicano Tejada, E. (2023). *Auditoría de seguridad informática. IFCT0109* (2.^a ed.). IC Editorial — eLibro.
- Evans, L. (2019). *Ethical Hacking: The Ultimate Guide to Using Penetration Testing....* Amazon Digital Services LLC — KDP.
- White, A. & Clark, B. (2017). *BTFM: Blue Team Field Manual*. CreateSpace Independent Publishing Platform.